

PENETRATION TESTING REPORT

Mediroza General Hospital

TARGET `https://medirozahospital.com`
ENGAGEMENT Black-Box Penetration Test — Batch B083, Week 4
TESTING WINDOW 27 Sep – 02 Oct 2026 (5 Days)
VERSION 1.0 — Final
CLASSIFICATION **CONFIDENTIAL** — Authorized Personnel Only

Author

Ali Abbas Qazi

LinkedIn: www.linkedin.com/in/ali-abbas-qazi

GitHub: <https://github.com/Ali-Abbas-Qazi/>

Document Control

Document Information

Document Title	Mediroza General Hospital — Penetration Testing Report
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Author	Ali Abbas Qazi
Engagement Type	Full Black-Box Penetration Test
Version	1.0 — Final
Classification	Confidential — Authorized Personnel Only

Revision History

Version	Date	Author	Description
0.1	29 Sep 2026	Ali Abbas Qazi	Initial draft — findings documented
0.9	01 Oct 2026	Ali Abbas Qazi	Full report drafted with evidence
1.0	02 Oct 2026	Ali Abbas Qazi	Final report — reviewed and issued

Distribution List

Recipient	Role	Access Level
Hospital CTO / IT Director	Primary Technical Recipient	Full Report
Chief Executive Officer	Executive Sponsor	Executive Summary Only
Legal & Compliance Team	Regulatory Oversight	Full Report
Ali Abbas Qazi	Penetration Tester / Author	Full Report

Table of Contents

- 01 Executive Summary
- 02 Scope and Methodology
- 03 Findings and Proof of Exploitation
 - VLN-01 Username Enumeration on Patient Portal Login
 - VLN-02 Authentication Bypass via SQL Injection
 - VLN-03 Weak Cryptographic Controls on Patient PDFs
 - VLN-04 Directory Indexing Enabled
 - VLN-05 Publicly Accessible Database Backup
 - VLN-06 Missing HTTP Security Headers
- 04 Risk Rating
- 05 Recommendations and Remediation

01 Executive Summary

Networkwalks Academy engaged a single authorized tester to conduct a five-day black-box penetration test of Mediroza General Hospital's public web presence at <https://medirozahospital.com>, under the terms of Batch B083, Week 4. The client provided written authorization limited strictly to the target domain, with social engineering and denial-of-service techniques explicitly out of scope. This report presents the full attack chain, six independently rated findings, and prioritized remediation guidance.

The engagement uncovered a complete compromise path from the public patient portal to the hospital's internal HR and shareholder records. Testing began with the patient portal login form, where inconsistent error messages first confirmed which usernames existed (username enumeration), and a classic SQL injection payload in the username field (admin'--) then bypassed authentication entirely, without ever supplying a valid password. That bypass exposed three password-protected patient pathology reports. Each PDF's encryption hash was extracted and cracked offline: two passwords (123456, password) fell within seconds to a 100-word built-in dictionary, and the third (!@#\$\$%^&) was recovered shortly after by switching to John the Ripper's default password.txt wordlist.

A follow-up Nikto scan of the web server found directory indexing enabled on three paths — /staff/, /patient/, and /old/ — and, ironically, the site's own robots.txt file listed all three, effectively pointing an attacker straight at them. The same scan also flagged a set of missing HTTP security headers. The /old/ directory served an unauthenticated, plaintext SQL database backup (mediroza_db_backup_2019.sql) containing full employee records (names, roles, salaries, national ID numbers, contact details) for thirty staff members and equity holdings for ten shareholders.

Overall engagement risk: **CRITICAL**. Six vulnerabilities were identified and independently rated — two Critical, two High, one Medium, and one Low. None of it required specialized tooling or elevated skill; a single tester working alone over five days reached unauthenticated patient data, PII, and confidential financial records. Section 04 gives the full risk breakdown and Section 05 sets out remediation steps ordered by priority.

02 Scope and Methodology

Engagement Parameters

Client: Mediroza General Hospital
Target: <https://medirozahospital.com>
Engagement type: Full black-box penetration test
Testing window: 27 September – 02 October 2026 (5 days)
Authorization: Written authorization granted by the client for security testing of its web infrastructure
Rules of engagement: Testing limited to the target domain only. No social engineering. No denial-of-service. No testing outside the agreed scope.

Because this was a black-box assessment, no credentials, source code, or internal documentation were provided ahead of time. Every finding below was reached the way an external, unauthenticated attacker would reach it — starting from nothing but the public URL. The overall approach loosely follows the structure of the OWASP Testing Guide and PTES: reconnaissance, authentication testing, exploitation, and post-exploitation analysis.

Approach

The five days followed a standard external web-application methodology: reconnaissance and attack-surface mapping, authentication and input-validation testing, exploitation and data extraction, post-exploitation server analysis, and reporting. In practice the phases overlapped — the directory-indexing and missing-headers findings, for instance, both came from the same Nikto scan revisited after the portal bypass had already been confirmed, rather than from a separate pass.

Tools and Techniques

Category	Tool / Technique	Purpose
Reconnaissance	Nikto v2.6.0	Web server misconfiguration and directory-indexing scan
Authentication Testing	Manual SQL Injection (admin'--)	Login-form input validation and authentication-bypass testing
Hash Extraction	OnlineHashCrack.com PDF Hash Extractor (pdf2john-based)	Converting encrypted PDFs to crackable \$pdf\$ hash format
Password Cracking	Networkwalks Password Cracker — built-in wordlist (100 entries)	Offline dictionary attack against extracted PDF hashes
Password Cracking (extended)	Networkwalks Password Cracker + John the Ripper default password.txt	Secondary dictionary attack after the built-in list failed
Testing Platform	Kali Linux 2026.2 (VirtualBox VM)	Isolated attack platform for all active testing

03 Findings and Proof of Exploitation

Findings are presented in the order of the four project milestones. Each is tracked under its own vulnerability ID (VLN-01 through VLN-06), with its own severity and CVSS 3.1 score, so Section 04's risk table maps one-to-one back to this section.

M1 — Initial Access

VLN-01: Username Enumeration via Differentiated Error Messages

Vulnerability ID	VLN-01
Location	Patient Portal Login — medirozahospital.com
Severity	Medium (CVSS 3.1: 5.3)
CWE Reference	CWE-204: Observable Response Discrepancy

The login form returned two distinct error states depending on what was typed into the username field: “Username not found” for an account that did not exist, and “Incorrect password” once a valid username was supplied. This is a textbook username-enumeration flaw — it lets an attacker silently build a list of valid accounts before attempting credential attacks against them.

Emergency: +27 11 555 0100 | Open 24/7

Staff Login | Find Us

Mediroza

Home | About | Doctors | Contact | Patient Portal

Patient Portal

Sign in to view your lab reports and results.

Username not found

Username

Password

☐ Show password

Sign in

© 2025 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS

1. Username Not found

Context: the portal confirming a submitted username does not exist.

Emergency: +27 11 555 0100 | Open 24/7

Staff Login | Find Us

Mediroza

Home About Doctors Contact Patient Portal

Patient Portal

Sign in to view your lab reports and results.

Incorrect password

Username

Password

☐ Show password

Sign in

© 2025 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS

2. Username Found, Wrong Password

Context: the portal confirming the username exists but the password is wrong.

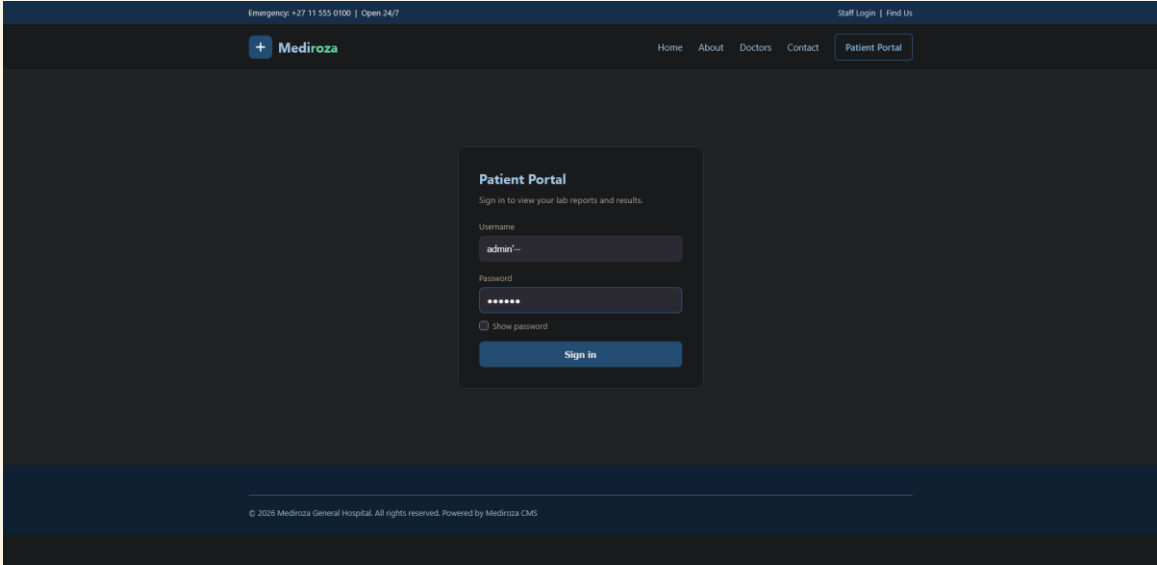
VLN-02: Authentication Bypass via SQL Injection

Vulnerability ID	VLN-02
Location	Patient Portal Login — Username Field
Severity	Critical (CVSS 3.1: 9.8)
CWE Reference	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
Payload Used	admin'--

The same field had a more serious problem underneath it: the username value was concatenated directly into the backend SQL query rather than passed as a parameter. Submitting admin'-- as the username, with any value in the password field, closed the string early and commented out the rest of the query — including the password check. The server-side query likely resembled the first line below; the injected payload reduced it to the second:

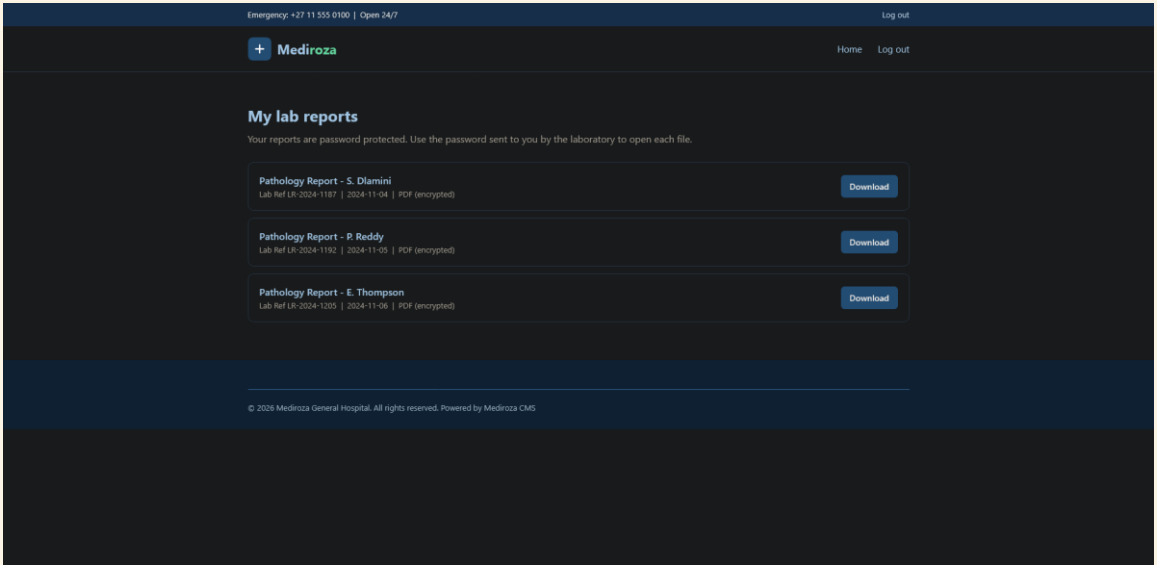
```
SELECT * FROM users WHERE username = 'admin'-- ' AND password = '[input]'  
SELECT * FROM users WHERE username = 'admin'
```

The application treated this as a fully authenticated login for the admin account, without ever validating a password.



3. SQLInjection on login page
Context: the injection payload admin'-- entered into the username field.

The bypass succeeded immediately and landed on the “My lab reports” page, revealing three downloadable, password-encrypted patient PDF lab reports — data that should never have been reachable without a legitimate, verified login.



4. Reports Found
Context: successful login bypass revealing three downloadable, encrypted patient PDF lab reports.

M2 — Data Extraction and Cryptographic Analysis

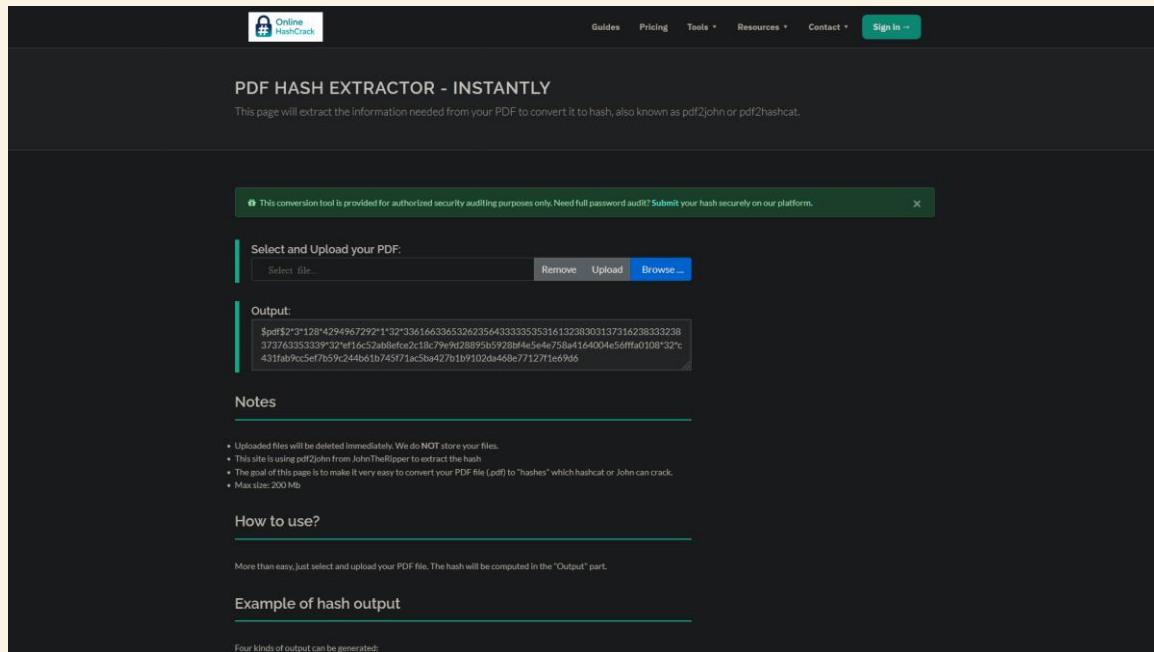
VLN-03: Weak Cryptographic Controls on Patient PDFs

Vulnerability ID	VLN-03
Location	patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf
Severity	High (CVSS 3.1: 7.5)

CWE Reference

CWE-521: Weak Password Requirements

The three reports retrieved from VLN-02 — covering patients S. Dlamini, P. Reddy, and E. Thompson — were each protected with PDF owner/user-password encryption (RC4-128, \$pdf\$2* format). Each file's password hash was extracted using onlinehashcrack.com's PDF hash extractor (a pdf2john-equivalent tool), producing a \$pdf\$-formatted hash for each report, saved as hash1.txt, hash2.txt, and hash3.txt.

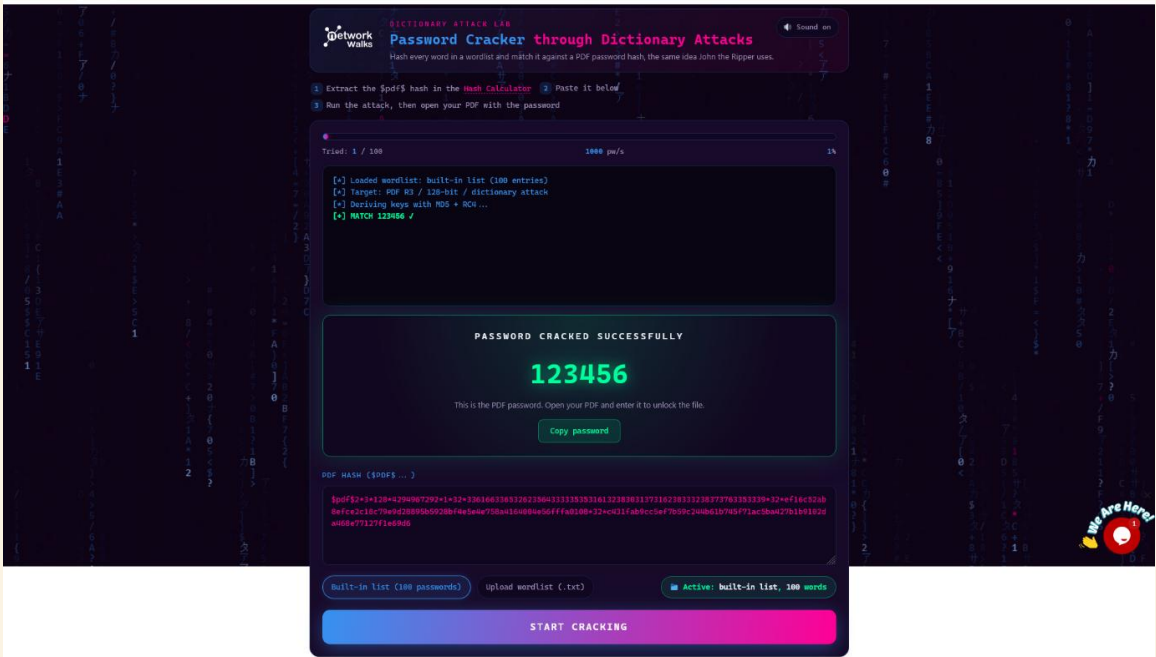


5. Find hashes for all PDF files

Context: successful extraction of the \$pdf\$ hashes for all three reports.

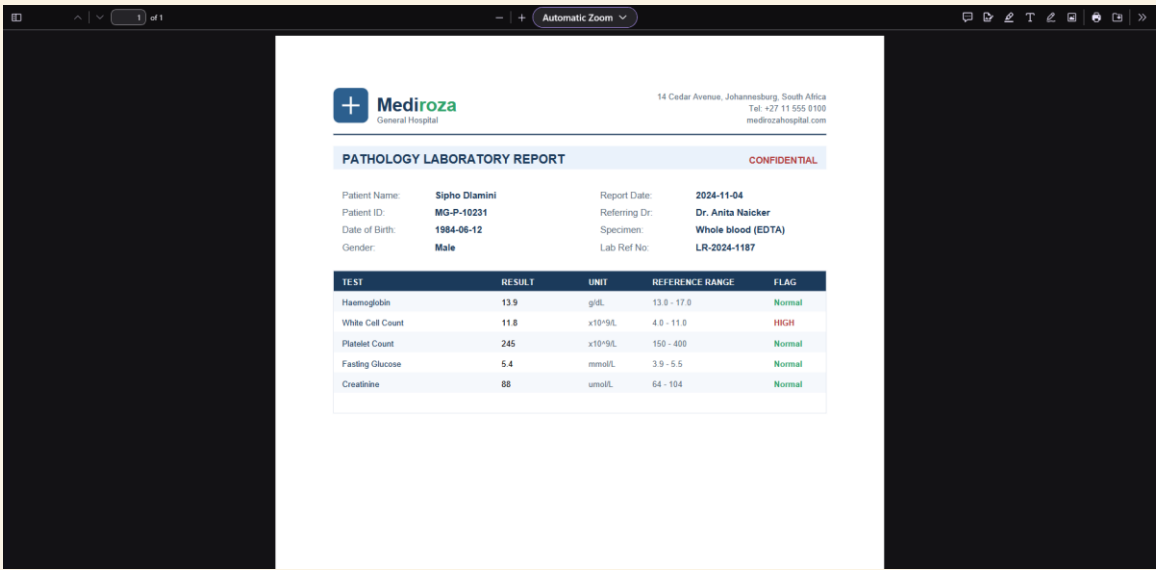
Each hash was then run through the Networkwalks Password Cracker, a browser-based dictionary-attack tool. The results varied by file:

1. Report 1 (hash1.txt) cracked instantly against the tool's 100-word built-in list — password: 123456.
2. Report 2 (hash2.txt) also fell to the built-in list — password: password.
3. Report 3 (hash3.txt) survived the built-in list. Uploading John the Ripper's default password.txt wordlist into the same tool succeeded shortly after — password: !@#\$%^&.



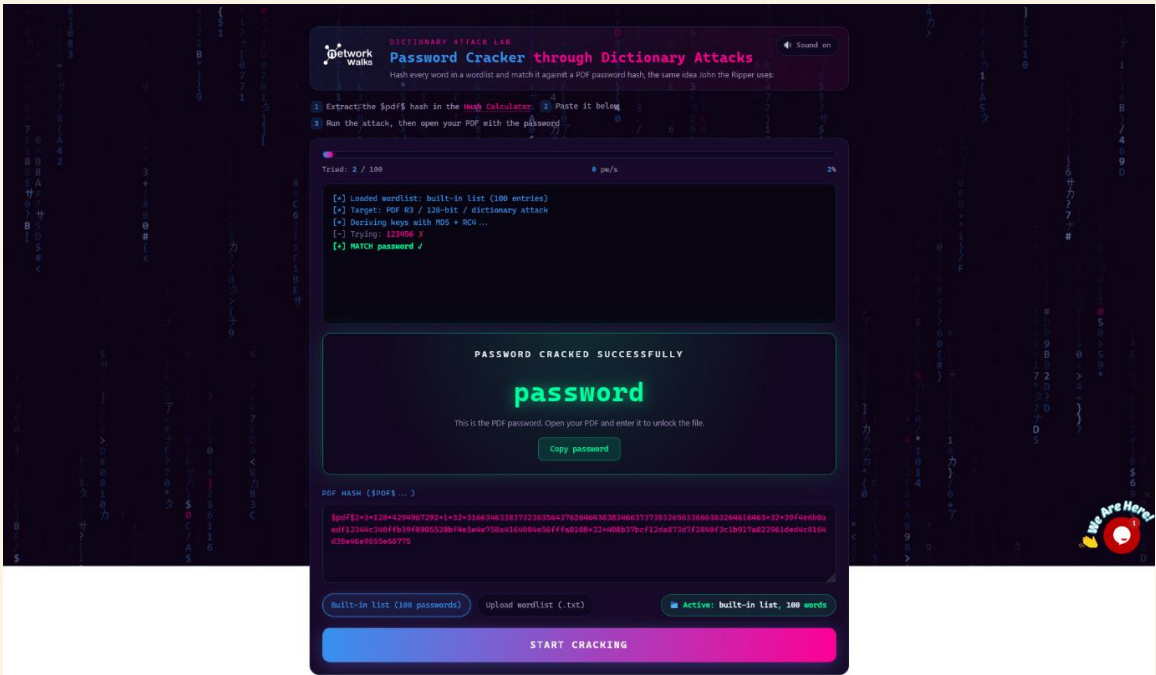
6a. hash1 cracked

Context: the Networkwalks tool successfully cracking hash1 using the built-in list.



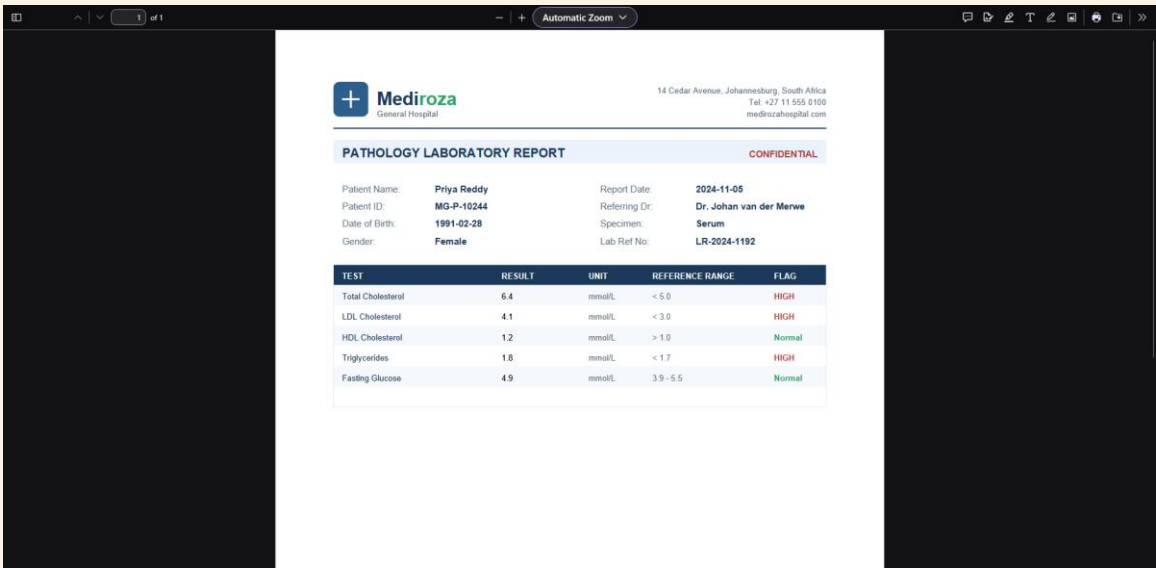
6a. Patient Report 1

Context: the decrypted Pathology Laboratory Report for Siphio Dlamini.



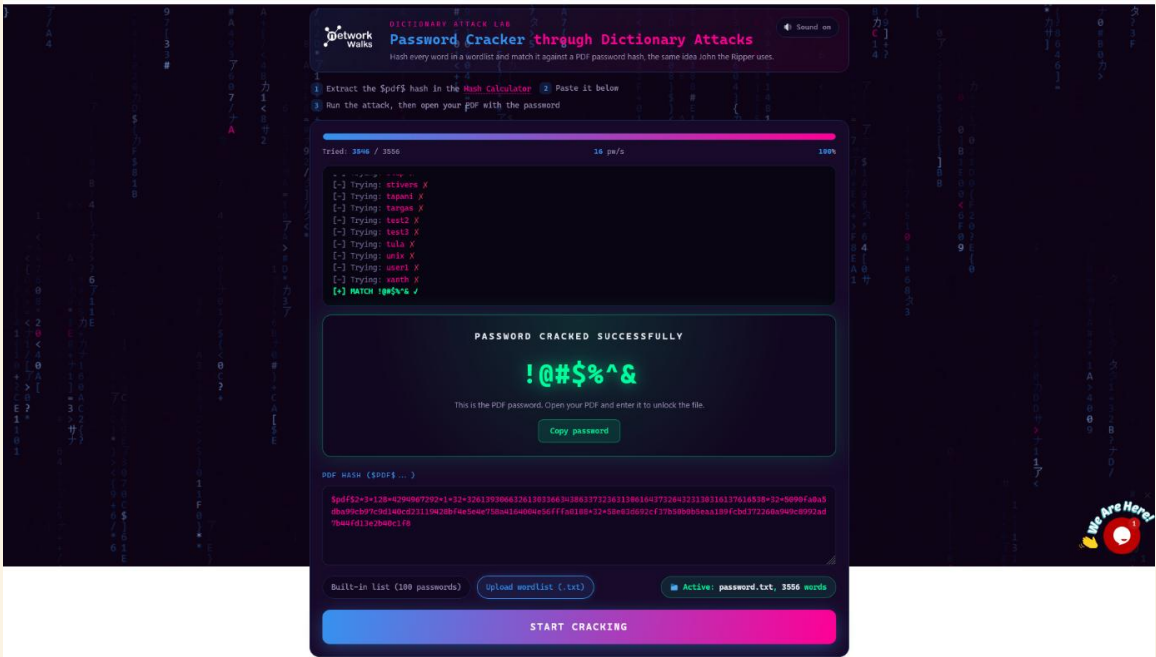
6b. hash2 cracked

Context: the Networkwalks tool cracking hash2.



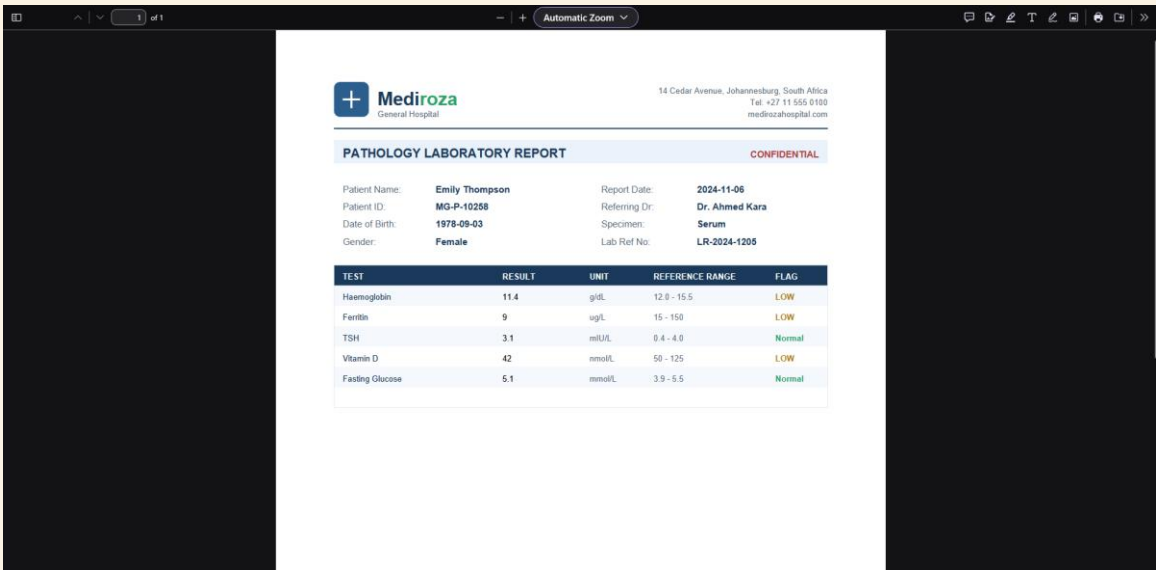
6b. Patient Report 2

Context: the decrypted report for P. Reddy.



6c. hash3 cracked

Context: the Networkwalks tool cracking hash3 using the uploaded JTR password.txt wordlist.



6c. Patient Report 3

Context: the decrypted report for E. Thompson.

The pattern across all three passwords — a numeric sequence, an English dictionary word, and a short keyboard-row string — shows the encryption step added almost no real protection once the hash could be extracted.

M3 — Critical Data Exposure

VLN-04: Directory Indexing Enabled

Vulnerability ID	VLN-04
Location	/old/, /staff/, /patient/
Severity	High (CVSS 3.1: 7.5)
CWE Reference	CWE-548: Exposure of Information Through Directory Listing

With application-layer access established, attention moved to the web server itself. Running the command below against the target returned directory indexing enabled on three separate paths. The scan also flagged that robots.txt explicitly disallowed all three of these paths — which, rather than hiding them, told an attacker exactly where to look.

```
$ nikto -h https://medirozahospital.com/
```

```

kali@kali: ~
└─$ nikto -h https://medirozahospital.com/
- Nikto v2.6.0

+ Target IP: 199.188.201.16
+ Target Hostname: medirozahospital.com
+ Target Port: 443

+ SSL Info: Subject: /CN=medirozahospital.com
            CN: medirozahospital.com
            SAN: medirozahospital.com, www.medirozahospital.com
            Ciphers: TLS_AES_256_GCM_SHA384
            Issuer: /C=US/O=SSL Corporation/CN=SSL.com TLS Issuing RSA CA R1
+ Platform: Unknown
+ Start Time: 2026-10-02 14:07:49 (GMT-4)

+ Server: LiteSpeed
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'x-turbo-charged-by' found, with contents: LiteSpeed.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [750500] /staff/: Directory indexing found.
+ [750500] /patient/: Directory indexing found.
+ [750500] /old/: Directory indexing found.
+ [999996] /robots.txt: contains 3 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [999996] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
^C

```

7. Found directories

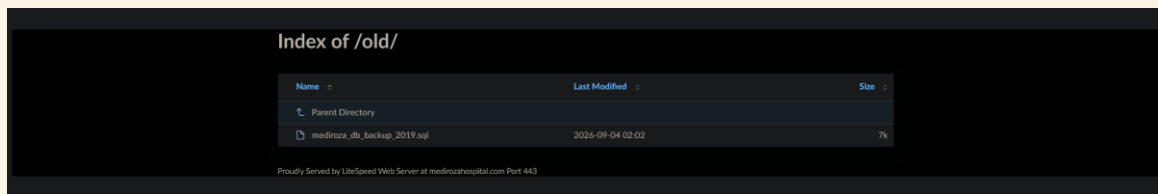
Context: the Kali terminal running the Nikto command, showing directory indexing found in /old/, /staff/, and /patient/, and the missing security headers noted below (VLN-06).

The /patient/ directory listed application files (login.php, portal.php, download.php, logout.php, an error_log, and a reports/ folder) but was otherwise access-restricted. The /old/ directory was not — which leads directly into the next finding.

VLN-05: Publicly Accessible Database Backup

Vulnerability ID	VLN-05
Location	/old/mediroza_db_backup_2019.sql
Severity	Critical (CVSS 3.1: 9.1)
CWE Reference	CWE-532: Insertion of Sensitive Information into Log File / CWE-200: Exposure of Sensitive Information

The /old/ directory served a single file, mediroza_db_backup_2019.sql, open to anyone who requested it, with no authentication of any kind.

**8. Unprotected Backup data found**

Context: the browser viewing the open /old/ directory and the downloadable .sql file.

The backup, generated by “Mediroza CMS 1.4.2” and dated 2019-08-27, contained two complete, plaintext database tables: a staff table with thirty employee records (full name, job title, department, email, phone number, national ID number, monthly salary, and start date) and a shareholders table with ten equity holders and their ownership percentages.

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost, Database: mediroza_db
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary`,`date_joined`) VALUES
(1,'Dr. Rajesh Nair','Chief Pathologist','Diagnostics Lab','r.nair@medirozahospital.com','+27 82 101 2007','8582191301001',110000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85811021022002',150000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.vandermerwe@medirozahospital.com','+27 82 103 2021','85841031033003',160000,'2007-01-22'),
(4,'Dr. Anita Malher','Consultant Cardiologist','Cardiology','a.malher@medirozahospital.com','+27 82 194 2028','85051041044004',112000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician, Internal Medicine','i.kara@medirozahospital.com','+27 82 105 2035','85061051055005',120000,'2013-02-15'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071061066006',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081071077007',50000,'2018-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091081088008',52000,'2016-08-23'),
(9,'Jamel Malik','IT System Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101091099009',58000,'2015-04-12'),
(10,'Thabo Ndlefe','Network Engineer','IT','t.ndlefe@medirozahospital.com','+27 82 110 2070','85111101110001',46000,'2017-10-02'),
(11,'Nomola Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','851211111121002',34000,'2016-01-19'),
(12,'Iveta Nelms','Registered Nurse','Pediatrics','i.nelms@medirozahospital.com','+27 82 112 2084','850811211232003',31000,'2017-06-07'),
(13,'Mogana Ndlovu','Registered Nurse','Cardiology','m.ndlovu@medirozahospital.com','+27 82 113 2093','850211311343004',35000,'2015-12-01'),
(14,'Zandile Ndlangu','Nursing Sister','Theatre','z.ndlangu@medirozahospital.com','+27 82 114 2098','850311411454005',42000,'2013-03-25'),
(15,'Kagiso Sibhah','Pharmacist','Pharmacy','k.sibhah@medirozahospital.com','+27 82 115 2105','850411511565006',45000,'2014-09-08'),
(16,'Madii Zulu','Pharmacy Assistant','Pharmacy','m.zulu@medirozahospital.com','+27 82 116 2112','850511611676007',20000,'2019-02-14'),
(17,'Thando Muni','Radiographer','Radiology','t.muni@medirozahospital.com','+27 82 117 2115','850611711787008',44000,'2014-07-18'),
(18,'Palena Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','850711811898009',41000,'2017-04-11'),
(19,'Daphny Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','850811911909010',41000,'2015-02-20'),
(20,'Kathia Gwendere','Lab Technician','Diagnostics Lab','k.gwendere@medirozahospital.com','+27 82 120 2140','850912012020002',35000,'2018-08-06'),
(21,'Dr. Shresh Noddy','Consultant Radiologist','Radiology','s.noddy@medirozahospital.com','+27 82 121 2147','851012112131001',110000,'2012-02-28'),
(22,'Dr. Farina Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','851112212242004',110000,'2013-10-17'),
(23,'Misha Singh','Physiotherapist','Rehabilitation','m.singh@medirozahospital.com','+27 82 123 2161','851212312353005',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','850124124264006',115000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','850212512575007',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','850312612686003',29000,'2018-01-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','850412712797008',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051281280801',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.vanwyk@medirozahospital.com','+27 82 129 2203','850612912919012',30000,'2015-08-24'),
(30,'Amelle Meki','Ward Clerk','Administration','a.meki@medirozahospital.com','+27 82 130 2210','850713013030003',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `share_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`share_held`,`share_class`) VALUES
(1,'Dr. Rajesh Nair',18.9,100000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.1,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Ndlefe',10.4,100000,'Ordinary'),
(6,'Sarah Botha',9.8,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Madii Zulu',7.8,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.8,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

9. Raw Unprotected BackUp Data

Context: the raw contents of mediroza_db_backup_2019.sql, exposing plaintext staff and shareholder tables.

Each staff record also carried a government-format national ID number and direct contact details. These are omitted from the tables below and are not reproduced in this report — their presence in the backup is noted here as part of the overall exposure. Salary and equity figures, which were the explicit scope of Milestone 3, are presented in full.

Exposed Staff Salary Data (30 records)

#	Employee	Role	Department	Monthly Salary (ZAR)	Date Joined
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R 138,000	2009-03-16
2	Sarah Botha	Chief Financial Officer	Finance	R 152,000	2011-07-01
3	Dr. Johan van der Merwe	Medical Director	Management	R 160,000	2007-01-22
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R 132,000	2012-09-10
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R 128,000	2013-02-18
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R 74,000	2018-05-04
7	Michael Roberts	HR Director	Human Resources	R 96,000	2010-11-15
8	Susan Pretorius	HR Officer	Human Resources	R 32,000	2016-08-23
9	Jameel Malik	IT Systems Administrator	IT	R 58,000	2015-04-12
10	Thabo Molefe	Network Engineer	IT	R 46,000	2017-10-02
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R 34,000	2016-01-19
12	Lerato Mokoena	Registered Nurse	Pediatrics	R 33,000	2017-06-07
13	Bongani Ndlovu	Registered Nurse	Cardiology	R 35,000	2015-12-01
14	Zanele Mahlangu	Nursing Sister	Theatre	R 42,000	2013-03-25
15	Kagiso Sithole	Pharmacist	Pharmacy	R 61,000	2014-09-08
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	R 26,000	2019-02-14
17	Themba Nkosi	Radiographer	Radiology	R 44,000	2016-07-30
18	Palesa Radebe	Radiographer	Radiology	R 43,000	2017-04-11
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	R 41,000	2015-05-20
20	Kavitha Govender	Lab Technician	Diagnostics Lab	R 35,000	2018-08-06
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R 130,000	2012-02-28
22	Dr. Fatima Patel	Pediatrician	Pediatrics	R 118,000	2013-10-17
23	Nisha Singh	Physiotherapist	Rehabilitation	R 48,000	2016-11-09
24	Dr. Vikram Chetty	Anaesthetist	Theatre	R 135,000	2011-06-13
25	David Smith	Facilities Manager	Operations	R 52,000	2014-01-27
26	Karen O'Connor	Billing Administrator	Finance	R 29,000	2018-03-19
27	James Wilson	Security Supervisor	Operations	R 27,000	2019-09-02
28	Linda Fourie	Receptionist	Front Office	R 19,000	2020-02-10
29	Peter van Wyk	Procurement Officer	Supply Chain	R 38,000	2015-08-24
30	Andile Mbeki	Ward Clerk	Administration	R 21,000	2019-11-05

Exposed Shareholder Data (10 records)

#	Shareholder	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.00%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.00%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.00%	120,000	Ordinary
4	Reddy Family Trust	11.00%	110,000	Ordinary
5	Thabo Molefe	10.00%	100,000	Ordinary
6	Sarah Botha	9.00%	90,000	Ordinary
7	Dr. Ahmed Kara	8.00%	80,000	Preferential
8	Naledi Zulu	7.00%	70,000	Ordinary
9	Michael Roberts	6.00%	60,000	Ordinary
10	Dr. Vikram Chetty	4.00%	40,000	Preferential

Ownership percentages sum to exactly 100%, confirming the table is the complete, unredacted capitalization structure of the hospital — competitively and personally sensitive information with no business reason to sit in a public, unauthenticated web directory.

VLN-06: Missing HTTP Security Headers

Vulnerability ID	VLN-06
Location	https://medirozahospital.com/ (site-wide)
Severity	Low (CVSS 3.1: 3.1)
CWE Reference	CWE-693: Protection Mechanism Failure

The same Nikto scan used for VLN-04 (see the terminal output above) also flagged a full set of missing HTTP response headers, none of which were present on any tested page:

- Content-Security-Policy
- X-Content-Type-Options
- Strict-Transport-Security
- Referrer-Policy
- Permissions-Policy

None of these are exploitable on their own, but their absence widens the blast radius of any future client-side bug — clickjacking, MIME-type sniffing, and protocol-downgrade attacks all become easier against a site with no baseline header hardening.

04 Risk Rating

Each vulnerability is rated independently using CVSS 3.1, reflecting both the ease of exploitation observed during testing and the sensitivity of the data or access it exposes.

ID	Finding	Risk	CVSS 3.1	Justification
VLN-01	Username Enumeration on Patient Portal Login	Medium	5.3	Distinct “Username not found” vs. “Incorrect password” responses let an attacker confirm valid accounts, narrowing the target list for credential-stuffing or brute-force attacks. CWE-204.
VLN-02	Authentication Bypass via SQL Injection	Critical	9.8	Unsanitized input in the login form allowed a classic admin'-- payload to comment out the password check entirely, granting unauthenticated access to restricted patient data. CWE-89 / OWASP A03:2021.
VLN-03	Weak Cryptographic Controls on Patient PDFs	High	7.5	Patient reports were protected with RC4-128 PDF encryption and dictionary-weak passwords. Two of three were recovered in under a second from a 100-entry wordlist. CWE-521.
VLN-04	Directory Indexing Enabled	High	7.5	Directory listing was enabled on /staff/, /patient/ and /old/, and robots.txt pointed directly at all three, letting an unauthenticated user browse and download their contents. CWE-548.
VLN-05	Publicly Accessible Database Backup	Critical	9.1	The /old/ directory served a full, unauthenticated SQL backup containing plaintext staff and shareholder records — a direct, unauthenticated path to HR and financial data. CWE-532.
VLN-06	Missing HTTP Security Headers	Low	3.1	Nikto flagged a missing Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy and Permissions-Policy, widening exposure to client-side attacks such as clickjacking and MIME-sniffing.

Risk Distribution

CRITICAL 2 (VLN-02, VLN-05) • **HIGH** 2 (VLN-03, VLN-04) • **MEDIUM** 1 (VLN-01) • **LOW** 1 (VLN-06)

Overall engagement risk: **CRITICAL**. The two Critical-rated findings are chained — the SQL injection alone exposes patient reports, and the backup exposure alone leaks HR and financial data, but an attacker does not need both to cause serious harm. Either finding in isolation would justify a Critical rating and immediate remediation.

05 Recommendations and Remediation

1. Eliminate Username Enumeration (VLN-01)

- Replace the two distinct error messages with a single generic response, such as “Invalid username or password,” for every failed login attempt regardless of cause.
- Add rate limiting and progressive delays on the login endpoint, with temporary account lockout or CAPTCHA after repeated failures from the same source.
- Ensure response timing is also consistent between a nonexistent username and a wrong password, since timing differences can leak the same information as the error text.

2. Remediate the SQL Injection (VLN-02)

- Rewrite all database queries using parameterized statements or prepared statements; never concatenate user input directly into SQL strings.
- Adopt an ORM or query-builder layer with injection protection built in, and add server-side input validation (allowlisting expected characters) as a second layer.
- Run the application's database account under least-privilege permissions, so that even a successful injection cannot read or modify tables beyond what the application strictly needs.
- Deploy a web application firewall as defense in depth — not as a replacement for fixing the underlying query handling.

3. Strengthen Cryptographic Controls on Patient Documents (VLN-03)

- Stop using static, user-memorable passwords (like 123456 or password) to protect patient PDFs; enforce a strong, randomly generated passphrase policy with minimum length and complexity for any document-level encryption.
- Upgrade PDF encryption from the current RC4-128 scheme to AES-256, which is both stronger and resistant to the extraction/cracking workflow used in this engagement.
- Consider replacing static passwords altogether with one-time access codes or links delivered through a secure, authenticated channel, so no password ever needs to be cracked offline.
- Add multi-factor authentication to the Patient Portal itself, so that even a successful login bypass cannot reach the reports without a second factor.

4. Disable Directory Indexing (VLN-04)

- Turn off directory listing at the web server level (Options -Indexes on Apache, autoindex off on Nginx, the equivalent LiteSpeed directive) across the entire site, not just the three paths found during this test.
- Return a generic 403/404 response for any directory request that lacks an index file, instead of listing its contents.
- Stop listing sensitive paths in robots.txt. robots.txt is a crawling convention, not an access control, and publishing /staff/, /patient/, and /old/ there functions as a map for attackers rather than a protection.

5. Secure Backup Storage (VLN-05)

- Move all backup files outside the public web root entirely, onto storage that is not reachable by any public URL.
- Encrypt backups at rest, and restrict access to them through authenticated, internal-only channels (VPN or private network segment), never direct HTTP access.
- Apply a defined retention and secure-deletion policy so outdated backups like this 2019 file are not left reachable indefinitely.
- Add monitoring and alerting on access to backup storage locations, so that any future unauthorized retrieval attempt is detected rather than silent.

6. Implement Missing Security Headers (VLN-06)

- Content-Security-Policy: default-src 'self'; to restrict where scripts, styles, and other resources can load from.
- X-Content-Type-Options: nosniff to stop the browser from MIME-sniffing responses away from the declared content type.
- Strict-Transport-Security: max-age=31536000; includeSubDomains to enforce HTTPS on every future visit.
- Referrer-Policy: strict-origin-when-cross-origin and a Permissions-Policy that disables unused browser features (camera, microphone, geolocation).

General Recommendations

- Commission a follow-up penetration test after remediation to confirm each finding has been closed, rather than relying on self-reported fixes.
- Given the volume of staff PII and national ID data exposed, review obligations under applicable data-protection law (POPIA, in a South African context) and consider whether breach-notification requirements apply.
- Establish a routine patching and configuration-review cadence for the CMS and web server, since this engagement found no evidence either had been updated since the 2019 backup was generated.
- Provide secure-coding and server-hardening training to the development and operations teams responsible for the Patient Portal and CMS.

--- End of report ---